SageMaker와 Bedrock IAM 정책 설계 실습

수강생 워크북 · 1일차 워크숍 1 · 90분 · 2026년 10월 30일 기준

AI 개발자가 학습 작업을 요청하고 승인된 모델을 호출하는 상황에서, 개발자와 AWS 서비스의 권한을 나누어 설계합니다. 정책을 직접 작성하고 정상 요청의 허용과 범위 밖 요청의 거부를 함께 검증합니다.

학습 완료 기준

1. 개발자 역할과 SageMaker 실행 역할의 신뢰 정책 및 권한 정책을 구분한다.
2. Action·Resource·Condition을 사용하여 필요한 범위의 권한을 작성한다.
3. SageMaker 작업 생성 권한과 iam:PassRole을 별도로 검증한다.
4. Bedrock 일반 호출과 스트리밍 호출 권한을 구분하고 24개 테스트를 비교한다.

진행 시간

시간	분량	활동
16:00-16:10	10분	상황 설명과 역할 구분
16:10-16:20	10분	환경과 ARN 확인
16:20-16:40	20분	미션 1 실행 역할의 S3 데이터 권한
16:40-16:45	5분	휴식
16:45-17:00	15분	미션 2 개발자 역할과 PassRole
17:00-17:15	15분	미션 3 Bedrock 모델 호출 권한
17:15-17:25	10분	전체 테스트와 오류 수정
17:25-17:30	5분	제출과 핵심 해설

기본 경로는 AWS 정책 시뮬레이션입니다. 학습 작업·버킷·IAM 역할을 생성하거나 모델을 호출하지 않습니다. 실제 모델 호출은 강사가 준비한 경우에만 선택 활동으로 진행합니다. [R5]

실습 준비와 실행 경로

필요한 환경

1. Python 3.10 이상, AWS CLI v2, 유효한 AWS 자격 증명을 준비합니다. 추가 Python 패키지는 없습니다.

2. 기본 실행에는 iam:SimulateCustomPolicy 권한이 필요합니다. 선택 AWS 문법 검증에는 access-analyzer:ValidatePolicy가 필요합니다. [R6, R8]

3. 압축을 풀고 workshop_iam 폴더에서 명령을 실행합니다. python이 없으면 Windows는 py -3, CloudShell은 python3로 바꿉니다.

```
python --version
aws --version
aws sts get-caller-identity
```

설정 파일 만들기

PowerShell에서는 아래 명령으로 복사합니다. Bash에서는 cp config.example.json config.json을 사용합니다.

```
Copy-Item config.example.json config.json
```

config.json의 account_id·region·team_id·bucket_name을 강사가 지정한 값으로 수정합니다. caller_principal_arn의 계정도 account_id와 맞춥니다. 기본 경로에서 버킷·역할·모델은 실제로 존재하지 않아도 됩니다. model_id와 denied_model_id는 서로 다르게 지정합니다.

```
python scripts/configure.py --config config.json --out work
```

경로	용도
work/student/developer.json	학습자가 작성할 개발자 권한
work/student/execution-data.json	학습자가 작성할 실행 역할의 데이터 권한
work/trust	분리해서 읽어볼 신뢰 정책
work/testcases.json	24개 요청과 기대 결과
work/reports	검증 결과 저장 위치

starter의 빈 Statement는 작성용 뼈대입니다. 실제 문장으로 채우기 전에는 배포·검증할 수 없습니다. configure.py는 이미 수정한 student 파일을 덮어쓰지 않습니다.

AWS 프로파일을 선택할 때는 검증 명령에 --profile workshop을 덧붙입니다. CloudShell 현재 자격 증명을 사용하면 생략합니다. 계정 권한이 없을 때는 7쪽의 요청 미리보기 경로로 진행합니다.

상황과 역할별 권한 설계

AnyCompany의 AI 개발팀은 하나의 S3 버킷에서 training/ 데이터를 읽어 학습하고 outputs/에 결과를 저장합니다. restricted/의 자료는 이 실습의 접근 범위에서 제외합니다. 개발자는 실습 이름의 학습 작업과 승인 모델 한 개만 사용합니다.

주체	허용해야 할 작업	허용하지 않을 작업
개발자 역할	실습 학습 작업 생성·조회·중지 지정 실행 역할을 SageMaker로 전달 승인 Bedrock 모델 일반·스트리밍 호출	운영 이름의 학습 작업 다른 실행 역할 전달 직접 S3 읽기·IAM 정책 수정
SageMaker 실행 역할	학습 경로 읽기·목록 조회 결과 경로 쓰기·목록 조회 버킷 위치 확인	제한 경로 읽기·목록 조회 학습 원본 수정·삭제 다른 버킷 읽기

예시 ARN 구조

```
S3 bucket
arn:aws:s3:::<BUCKET>

S3 object
arn:aws:s3:::<BUCKET>/training/*

SageMaker training job
arn:aws:sagemaker:<REGION>:<ACCOUNT>:training-job/workshop-team01-*

Execution role
arn:aws:iam::<ACCOUNT>:role/WorkshopSageMaker-team01

Bedrock foundation model
arn:aws:bedrock:<REGION>::foundation-model/<MODEL_ID>
```

검증에 사용할 ARN은 work/testcases.json에 치환되어 있습니다. 먼저 스스로 구성해 보세요. Bedrock foundation-model ARN은 계정 ID 자리가 비어 있는 점을 확인합니다.

설계 질문 개발자에게 S3 직접 읽기 권한을 주지 않아도 학습 데이터에 간접 접근할 수 있는 이유는 무엇인가요

실습의 거부는 제공한 초안 정책의 범위에서 평가합니다. 실제 계정에서는 다른 허용 정책·버킷 정책·조직 정책 등을 함께 확인해야 합니다. [R1, R2, R5, R7]

미션 1 실행 역할의 데이터 권한

소요 시간 20분 · 수정 파일 work/student/execution-data.json

요구사항

1. s3:GetBucketLocation은 지정 버킷에만 허용합니다.

2. s3:ListBucket은 지정 버킷의 training/·outputs/ 접두사 요청에만 허용합니다.

3. s3:GetObject는 training/*에만 허용합니다.

4. s3:PutObject는 outputs/*에만 허용합니다. 원본 삭제·덮어쓰기와 restricted/ 접근은 허용하지 않습니다.

작성 순서

버킷 작업과 객체 작업을 서로 다른 문장으로 작성합니다. 목록 조회에는 s3:prefix 조건을 사용하고, 객체 읽기·쓰기에는 객체 ARN을 사용합니다. 예시는 같은 계정, SSE-S3, 다른 허용 정책이 없는 상황입니다. [R7]

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "ChooseADescriptiveName",
      "Effect": "Allow",
      "Action": "<필요한 작업>",
      "Resource": "<적절한 ARN>"
    }
  ]
}
```

버킷 ARN을 사용하는 작업과 객체 ARN을 사용하는 작업을 각각 적어 보세요

s3:prefix 조건과 목록 조회 결과에 포함될 객체 경로는 어떤 관계인가요

완료 확인

```
python scripts/simulate.py --workdir work --stage execution
```

E01-E10의 10개 테스트를 확인합니다. 허용 테스트뿐 아니라 제한 경로·원본 변경·다른 버킷 요청의 거부도 만족해야 합니다. 이 파일은 전체 학습 실행 권한 중 S3 데이터 접근 부분입니다. ECR·로그·네트워크 등의 실제 학습 의존성은 기본 미션에서 제외합니다. [R2, R10]

미션 2 개발자 역할과 PassRole

소요 시간 15분 · 수정 파일 work/student/developer.json

학습 작업을 요청하는 주체와 실행하는 주체

개발자는 CreateTrainingJob 요청에 RoleArn을 지정합니다. SageMaker는 지정한 실행 역할을 맡아 데이터에 접근합니다. 개발자에게는 학습 작업 API 권한과 지정 역할을 전달하는 권한이 각각 필요합니다. [R2, R3]

설계 항목	작성할 내용
학습 작업 작업명	CreateTrainingJob·DescribeTrainingJob·StopTrainingJob
작업 리소스 범위	현재 리전·계정의 workshop-팀명-* 학습 작업
역할 전달 작업	iam:PassRole
전달할 역할	WorkshopSageMaker-팀명 역할 하나
전달 대상 서비스 조건	iam:PassedToService = sagemaker.amazonaws.com

스스로 구분할 세 가지

1. 개발자 권한 정책: 어떤 SageMaker API를 호출하고 어떤 역할을 전달할 수 있는가
2. 실행 역할 신뢰 정책: SageMaker가 이 역할을 맡을 수 있는가
3. 실행 역할 권한 정책: SageMaker가 역할을 맡은 뒤 어떤 데이터에 접근할 수 있는가

work/trust/sagemaker-trust.json을 읽어 보세요. 이 신뢰 정책에 S3 읽기 권한을 넣지 않습니다. 사람에게 실행 역할을 직접 맡기도록 신뢰 정책을 바꾸지도 않습니다.

CreateTrainingJob이 allowed인데 iam:PassRole이 denied라면 무엇을 수정해야 하나요

전달할 역할 ARN만 제한하고 서비스 조건을 생략하면 어떤 요구사항을 놓치나요

이 단계에서는 Bedrock 문장을 아직 작성하지 않아 D09-D10이 실패할 수 있습니다. D01-D08과 D13-D14를 먼저 확인하고, 다음 미션에서 나머지를 완성합니다.

```
python scripts/simulate.py --workdir work --stage developer
```

미션 3 Bedrock 모델 호출 권한

소요 시간 15분 · 개발자 정책에 Bedrock 권한 문장을 추가합니다.

요구사항

1. config.json의 model_id 한 개만 지정 리전에서 호출할 수 있어야 합니다.

2. 일반 응답과 스트리밍 응답을 모두 허용합니다.

3. denied_model_id와 다른 리전의 동일 모델 요청은 허용하지 않습니다.

4. 개발자의 SageMaker·PassRole 문장은 유지합니다.

사용할 API	필요한 IAM 작업
InvokeModel 또는 Converse	bedrock:InvokeModel
InvokeModelWithResponseStream 또는 ConverseStream	bedrock:InvokeModelWithResponseStream

Converse를 사용한다고 bedrock:Converse라는 IAM 작업을 작성하지 않습니다. 이 실습은 직접 foundation-model ARN을 사용하며, 추론 프로파일 경로는 별도 확장 과제입니다. [R4, R9]

승인 모델 ARN에 계정 ID를 넣으면 안 되는 이유를 확인하고 완성해 보세요

Resource를 *로 바꾸면 어떤 테스트가 실패해야 하나요

검증 실행

```
python scripts/simulate.py --workdir work --stage developer
```

D01-D14를 확인합니다. D09와 D10은 allowed, D11과 D12는 denied가 기대 결과입니다. D13·D14는 개발자 정책에 불필요한 데이터 접근·권한 수정 작업을 추가하지 않았는지 확인합니다.

실제 호출과 구분

기본 검증은 IAM 정책 평가입니다. 모델의 해당 리전 제공 여부, 온디맨드 지원, 계정의 모델 접근 상태나 공급자 조건을 확인하지 않습니다. allowed 결과만으로 실제 호출 성공을 단정하지 않습니다. [R4, R5]

전체 검증과 결과 읽기

소요 시간 10분 · JSON 구조 검사와 권한 평가를 구분하여 실행합니다.

1 로컬 구조 검사

```
python scripts/validate.py --workdir work
```

JSON 파싱, 필수 필드, 빈 Statement, 미치환 값을 검사합니다. AWS 작업명과 리소스 유형의 유효성까지 판정하는 검사는 아닙니다.

2 AWS 문법과 권고사항 검사

```
python scripts/validate.py --workdir work --aws
```

IAM Access Analyzer의 ValidatePolicy를 호출합니다. 오류를 수정하고 보안 경고·일반 경고·제안도 읽어 봅니다. 권한이 없으면 이 단계는 강사가 대신 실행합니다. [R8]

3 전체 24개 요청 평가

```
python scripts/simulate.py --workdir work
```

각 요청은 작업 하나와 리소스 하나로 분리됩니다. PassRole과 S3 목록 요청은 필요한 조건값을 함께 전달합니다. 실제 학습 작업을 만들거나 리소스를 수정하지 않습니다. [R5]

```
아래는 출력 형식 예시이며 실제 실행 기록이 아닙니다.
PASS E01 expected=allowed actual=allowed
PASS E03 expected=denied actual=implicitDeny
PASS D05 expected=allowed actual=allowed
PASS D08 expected=denied actual=implicitDeny
  MissingContextValues: iam:PassedToService
```

allowed는 제공한 정책에서 허용, implicitDeny는 허용 조건 미충족 또는 허용 없음, explicitDeny는 명시적 거부입니다. D08은 의도적으로 조건값을 생략한 음성 테스트이므로 MissingContextValues가 표시되어도 기대 거부를 만족할 수 있습니다.

AWS 권한이 없을 때

```
python scripts/simulate.py --workdir work --dry-run
```

이 명령은 요청 JSON만 준비하며 허용·거부를 평가하지 않습니다. request-preview 보고서를 강사에게 전달하거나 다음 두 쪽의 기대 결과를 직접 분석하세요. 실제 AWS 결과와 혼동하여 제출하지 않습니다.

실행 역할 테스트 기록

예상 결과를 읽고, 실제 실행 뒤 마지막 열에 판정과 이유를 적습니다. 조건과 리소스 ARN의 원문은 work/testcases.json에 있습니다.

ID	요청	기대	실제 및 근거
E01	학습 데이터 읽기	허용	
E02	결과 데이터 저장	허용	
E03	제한 데이터 읽기 차단	거부	
E04	학습 원본 덮어쓰기 차단	거부	
E05	학습 원본 삭제 차단	거부	
E06	학습 경로 목록 조회	허용	
E07	제한 경로 목록 조회 차단	거부	
E08	버킷 전체 목록 조회 차단	거부	
E09	다른 버킷 읽기 차단	거부	
E10	버킷 위치 확인	허용	

버킷 전체 목록 요청 E08을 허용하지 않는 이유와 운영 시 확인할 사항

읽기 전용 입력 경로와 쓰기 전용 결과 경로를 분리할 때의 효과

SageMaker가 실제로 사용하는 목록 요청의 prefix 형식에 따라 정책 조정이 필요할 수 있습니다. 여기서는 testcases.json에 지정한 요청 문맥을 기준으로 데이터 접근 설계를 평가합니다. 실제 학습을 운영할 때는 서비스 호출 패턴과 버킷 정책도 함께 검증합니다. [R2, R5, R7]

개발자 역할 테스트 기록

D01의 생성 권한과 D05의 역할 전달 권한은 서로 다른 평가입니다. 이 결과를 묶어 실제 CreateTrainingJob 요청 성공으로 해석하지 않습니다.

ID	요청	기대	실제 및 근거
D01	실습 작업 생성	허용	
D02	실습 작업 조회	허용	
D03	실습 작업 중지	허용	
D04	운영 작업 생성 차단	거부	
D05	지정 역할을 SageMaker로 전달	허용	
D06	다른 역할 전달 차단	거부	
D07	같은 역할을 Lambda로 전달 차단	거부	
D08	전달 대상 조건 누락 시 허용 안 됨	거부	
D09	승인 모델 일반 호출	허용	
D10	승인 모델 스트리밍 호출	허용	
D11	미승인 모델 호출 차단	거부	
D12	다른 리전 동일 모델 호출 차단	거부	
D13	개발자 직접 S3 읽기 차단	거부	
D14	개발자 IAM 정책 수정 차단	거부	

D05와 D07의 차이를 Resource와 Condition으로 설명하세요

Bedrock 일반 호출만 되고 스트리밍이 안 될 때 확인할 IAM 작업

오류 진단과 제출

오류를 찾는 순서

증상	먼저 확인할 항목
학습 데이터 읽기가 거부됨	GetObject에 버킷 ARN이 아닌 /training/* 객체 ARN을 지정했는가
정상 목록 조회가 거부됨	ListBucket의 버킷 ARN과 s3:prefix 문맥값이 일치하는가
학습 생성은 허용인데 역할 전달은 거부됨	개발자 정책의 iam:PassRole과 전달할 역할 ARN·서비스 조건을 확인했는가
다른 모델 호출까지 허용됨	Bedrock 문장에 Resource * 또는 넓은 모델 와일드카드를 넣었는가
시뮬레이터 API 자체가 AccessDenied	현재 실행 자격 증명에 iam:SimulateCustomPolicy가 있는가

제출물과 평가 기준

항목	배점	제출할 증거
역할 구분	20점	역할별 권한 표와 신뢰 정책 설명
실행 역할 데이터 정책	25점	execution-data.json과 E01-E10 결과
개발자와 PassRole	25점	개발자 정책의 작업·역할·서비스 범위
Bedrock 제한	20점	승인 모델 허용 및 다른 모델·리전 거부
검증과 수정 근거	10점	실제 평가인지 요청 미리보기인지 구분하고 오류 원인 기록

정책 두 개와 테스트 보고서, 수정 이유를 제출합니다. 전체 24개 테스트 통과가 목표입니다. 제한된 테스트 통과만으로 모든 가능한 요청이 최소 권한이라는 증명이 되지는 않습니다.

오늘 가장 넓게 줄 수 있었지만 범위를 줄인 권한과 그 이유

AWS 자격 증명·임시 토큰을 제출하지 않습니다. 기본 경로에서는 AWS 리소스를 만들지 않았으므로 삭제할 리소스가 없습니다. 선택 실호출을 진행했다면 강사 가이드의 정리 절차를 따릅니다.

선택 활동과 참고 자료

정책을 실제로 적용하고 Bedrock 호출하기

강사가 준비한 전용 개발자 역할에 검증된 정책을 적용한 경우에 진행합니다. IAM 변경과 모델 추론 요금이 발생하는 선택 활동이며 기본 90분 완료 기준에는 포함하지 않습니다.

```
python scripts/live_bedrock.py --workdir work \
  --profile instructor --allow-inference
```

위 명령의 줄바꿈은 Bash 표기입니다. PowerShell에서는 한 줄로 입력하세요. 원본 IAM 역할·사용자는 전용 개발자 역할의 신뢰 정책에 허용되어 있어야 하고 해당 역할에 대한 sts:AssumeRole 권한이 필요합니다. 스크립트는 개발자 역할을 맡은 임시 자격 증명으로 승인 모델을 한 번 호출합니다.

실제 SageMaker 학습은 진행하지 않습니다. 전체 실행 역할에는 ECR 이미지 접근, CloudWatch Logs·지표, 선택 KMS·VPC 권한 등이 추가로 필요할 수 있습니다. 현재 execution-data.json을 전체 실행 역할의 완성본으로 사용하지 않습니다. [R2, R10]

확장 토의

1. 입력 데이터가 SSE-KMS라면 S3 권한 외에 어떤 키 사용 권한과 키 정책을 확인해야 할까요
2. 추론 프로파일을 쓰면 프로파일 ARN과 연결된 리전의 모델 ARN을 어떻게 제한할까요 [R9]
3. 직접 S3 접근을 막아도 SageMaker 작업을 통해 데이터를 처리할 수 있습니다. 실행 역할과 실행 코드의 통제는 어떻게 보완해야 할까요

핵심 공식 문서

[R1] IAM 역할과 서비스 역할
https://docs.aws.amazon.com/IAM/latest/UserGuide/id_roles.html

[R2] SageMaker 실행 역할과 학습 작업 권한
https://docs.aws.amazon.com/sagemaker/latest/dg/sagemaker-roles.html

[R3] 서비스에 역할을 전달하는 PassRole
https://docs.aws.amazon.com/IAM/latest/UserGuide/id_roles_use_passrole.html

[R4] Bedrock 추론 API의 권한
https://docs.aws.amazon.com/bedrock/latest/userguide/inference-prereq.html

[R5] IAM 정책 시뮬레이터와 실제 환경의 차이
https://docs.aws.amazon.com/IAM/latest/UserGuide/access_policies_testing-policies.html

[R7] S3 자격 증명 기반 정책 예제
https://docs.aws.amazon.com/AmazonS3/latest/userguide/example-policies-s3.html

전체 참고 자료는 강사 가이드와 README.md에 있습니다. 모델·리전·계정 설정은 강의 전에 다시 확인하세요.